PORTFOLIO SAMPLE -- CLIENT INFORMATION REDACTED

WEB APPLICATION

SECURITY ASSESSMENT REPORT

Target Organization: **[REDACTED]**
Target URL: **[REDACTED]**
Assessment Date: April 2026
Assessed By: Mofic Koudmani
Report Version: 1.0
Classification: **Portfolio Sample -- Client Information Redacted**

Prepared by
Mofic Koudmani
Cybersecurity Student, B.A.S. Cybersecurity and Ethical Hacking
Broward College | Microsoft AZ-900 Certified | CompTIA Security+ (In Progress)
mofickoudmani@gmail.com | (954) 249-5068

1. EXECUTIVE SUMMARY

This report presents the findings of a web application security assessment conducted on a live e-commerce website in April 2026. Client and target information has been redacted for public distribution. The assessment was performed with full written authorization from the client and followed a black-box methodology simulating an external attacker with no prior system knowledge.

The target was a WordPress and WooCommerce e-commerce platform handling customer orders and payment transactions. The assessment identified 6 findings across High, Medium, and Low severity levels, plus one informational note. All findings were reported to the client with a prioritized remediation roadmap.

0	3	2	1
CRITICAL	HIGH	MEDIUM	LOW

OVERALL RISK RATING

MEDIUM-HIGH

The site had a solid foundation with HTTPS correctly implemented, reCAPTCHA in place, and an active cookie consent system. However, information disclosure vulnerabilities, gaps in admin access controls, and missing security headers required attention before the site could be considered adequately secured for an e-commerce environment.

2. SCOPE AND METHODOLOGY

2.1 What Was Assessed

The following were in scope for this assessment:

- **Primary website and all publicly accessible pages and endpoints**
- **HTTP response headers and SSL/TLS configuration**
- **Client-side JavaScript and third-party script dependencies**
- **CMS and e-commerce platform configuration indicators visible from the public side**

The following were explicitly out of scope:

- **Internal network or server infrastructure**
- **Database systems**
- **Payment processor integrations**
- **Social engineering or phishing attacks against staff**
- **Any form of destructive testing**

2.2 How the Assessment Was Conducted

This was a black-box assessment approached from the perspective of an external attacker with no prior knowledge of the system. Techniques included:

- **Passive reconnaissance: reviewing publicly visible information in page source, HTTP responses, and metadata**
- **Configuration review: examining security-relevant settings detectable from the client side**
- **HTTP header analysis: checking what security response headers were and were not present**
- **Technology fingerprinting: identifying CMS, plugins, and version numbers in use**
- **Third-party dependency analysis: cataloguing and evaluating external scripts**
- **Manual source code inspection**

2.3 Tools Used

- **PhishGuard (custom Python and Flask security analysis tool developed by the assessor)**
- **Chrome DevTools for header inspection and JavaScript analysis**
- **Manual source code review**
- **OWASP Testing Guide v4.2 as the reference methodology**

3. FINDINGS SUMMARY

#	Finding Title	Severity	Status
1	CMS and E-Commerce Platform Version Disclosure	High	Open
2	CMS Admin Panel Publicly Accessible	High	Open
3	Missing HTTP Security Headers	High	Open
4	Excessive Third-Party Script Dependencies	Medium	Open
5	Analytics Configuration Exposes Internal Store Details	Medium	Open
6	Business Contact Information Exposed to Automated Harvesting	Low	Open
7	HTTPS Correctly Implemented	Info	Open

4. DETAILED FINDINGS

FINDING 01 CMS AND E-COMMERCE PLATFORM VERSION DISCLOSURE	
SEVERITY	● High
LOCATION	[REDACTED -- Client Domain] (HTML meta generator tag and page source)
DESCRIPTION	The website publicly disclosed its CMS platform and exact version numbers in the HTML source code. The meta generator tag revealed the WordPress version and the page source exposed the WooCommerce version. Attackers routinely scan for this information to identify sites running known vulnerable versions and target them with published exploits.
IMPACT	When an attacker knows the exact software versions running on a site, they can search public vulnerability databases for known CVEs and launch targeted attacks without additional reconnaissance. This is especially concerning for an e-commerce site that handles customer orders and payment information.

REMEDIATION	Remove the CMS generator meta tag via the theme's functions.php file. Suppress e-commerce plugin version information through the hosting provider or a developer. Keep all CMS core software, plugins, and themes updated to the latest versions at all times.

FINDING 02 CMS ADMIN PANEL PUBLICLY ACCESSIBLE

SEVERITY	● High
LOCATION	[REDACTED -- Client Domain]/wp-admin/
DESCRIPTION	The CMS administrative login page was reachable from anywhere on the internet with no additional access controls in place. Because the admin path is identical on all WordPress installations, automated bots continuously scan for it and attempt login using known credential combinations. References to this path were confirmed in the page source during the assessment.
IMPACT	A successful login to the admin panel gives an attacker complete control over the website. They could install malware, steal customer data, redirect visitors to phishing pages, or take the site fully offline. Even with a strong password, repeated automated login attempts create an ongoing performance and security risk.
REMEDIATION	Enable Two-Factor Authentication on all admin accounts using a plugin such as WP 2FA. Restrict admin panel access to known IP addresses via the hosting control panel or .htaccess file. Install a brute-force protection plugin such as Wordfence or Limit Login Attempts Reloaded.

FINDING 03 MISSING HTTP SECURITY HEADERS

SEVERITY	● High
LOCATION	[REDACTED -- Client Domain] (HTTP response headers)
DESCRIPTION	The website was missing several critical HTTP security response headers including Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, and Referrer-Policy. These headers instruct browsers on how to safely handle the site's content and form a free, simple defense layer that most sites overlook.
IMPACT	Absence of these headers exposes the site and its visitors to cross-site scripting (XSS) attacks that can steal customer session tokens, clickjacking attacks that overlay invisible malicious elements over the real site, and information leakage to third-party referrers. These risks are heightened on an e-commerce platform.
REMEDIATION	Add X-Frame-Options, X-Content-Type-Options, and Referrer-Policy headers via the .htaccess file. Use a security hardening plugin to assist with Content-Security-Policy configuration. Verify implementation using securityheaders.com after making changes.

FINDING 04 EXCESSIVE THIRD-PARTY SCRIPT DEPENDENCIES

SEVERITY	● Medium
LOCATION	[REDACTED -- Client Domain] (10 external JavaScript files detected in page source)
DESCRIPTION	The website loaded 10 JavaScript files from external third-party services. Each external script is a dependency outside the client's direct control. If any of those services were compromised, malicious code could be injected into the site and execute in every visitor's browser. This attack pattern, known as a Magecart or supply chain attack, has been used specifically against e-commerce sites to silently steal payment card data.

IMPACT	A compromised third-party script could steal customer payment information, redirect visitors to scam pages, or expose personal data without the site owner's knowledge. The more external scripts a site loads, the larger the potential attack surface.
REMEDIATION	Audit all external scripts and remove those not providing essential business value. Implement Subresource Integrity (SRI) checks for retained scripts. Configure a Content Security Policy that whitelists only approved script sources.

FINDING 05 ANALYTICS CONFIGURATION EXPOSES INTERNAL STORE DETAILS

SEVERITY	● Medium
LOCATION	[REDACTED -- Client Domain] (E-commerce analytics JavaScript configuration)
DESCRIPTION	The e-commerce analytics configuration was visible in the page source and included the store's internal unique identifier (UUID). While not a critical vulnerability on its own, this provides attackers with a fingerprint for targeting the specific installation. The site also transmitted detailed user behavior data to multiple third-party analytics platforms.
IMPACT	The exposed store UUID makes it easier for an attacker to identify and target the specific e-commerce installation. From a privacy standpoint, customer browsing and purchasing behavior was being shared with outside parties, which may raise compliance concerns.
REMEDIATION	Remove or obfuscate the store UUID from the public page source. Review and minimize what customer data is transmitted to analytics platforms. Ensure the cookie consent system accurately reflects all active tracking.

FINDING 06 BUSINESS CONTACT INFORMATION EXPOSED TO AUTOMATED HARVESTING

SEVERITY	● Low
LOCATION	[REDACTED -- Client Domain] (footer and chat widget)
DESCRIPTION	The primary business phone number appeared in plain text in the HTML source code in multiple locations. While intentional for customer contact purposes, plain-text phone numbers are easily collected by automated scrapers and can be sold to spam services or used in social engineering attempts against staff.
IMPACT	Low direct technical risk. The main concern is that the number can be harvested and used in unsolicited contact campaigns or as part of a social engineering attempt targeting business employees.
REMEDIATION	Render the contact number using a JavaScript snippet rather than plain HTML text to prevent automated harvesting while keeping it functional for real visitors. Ensure staff are aware of social engineering and voice phishing tactics.

FINDING 07 HTTPS CORRECTLY IMPLEMENTED

SEVERITY	● Info
LOCATION	[REDACTED -- Client Domain]
DESCRIPTION	The website correctly used HTTPS across all pages with a valid SSL certificate in place. No mixed content was detected. HTTP traffic was properly redirected to HTTPS.
IMPACT	Positive finding. Customer data transmitted to and from the site was protected by transport-layer encryption.

REMEDIATION	Maintain the current HTTPS implementation. Automate SSL certificate renewal to prevent expiry. Consider adding an HTTP Strict Transport Security (HSTS) header to prevent protocol downgrade attacks.

5. WHAT WAS WORKING WELL

The following security controls were correctly implemented and maintained during the assessment:

- **HTTPS and TLS Encryption:** All pages were served over encrypted HTTPS with a valid certificate and no mixed content detected.
- **Google reCAPTCHA:** Active on the site, providing protection against automated bot submissions.
- **Cookie Consent Management:** A compliant cookie consent system was in place giving visitors control over tracking preferences.
- **No Exposed Credentials:** No hardcoded API keys, passwords, or credentials were found in publicly accessible source code.
- **Clean Mixed Content:** All resources loaded over HTTPS with no unencrypted HTTP resources present.

6. RECOMMENDED NEXT STEPS

The following remediation actions were recommended in priority order:

Priority	Timeline	Action
1 -- HIGH	Immediate	Enable Two-Factor Authentication on all CMS admin accounts
2 -- HIGH	Immediate	Remove the CMS version number from the meta generator tag
3 -- HIGH	Immediate	Restrict admin panel access by IP address via .htaccess
4 -- HIGH	7 Days	Add missing HTTP security headers (X-Frame-Options, X-Content-Type-Options, Referrer-Policy)
5 -- MEDIUM	30 Days	Audit and reduce third-party JavaScript dependencies
6 -- MEDIUM	30 Days	Review analytics data collection for privacy compliance
7 -- LOW	Ongoing	Set up automated monitoring for CMS core and plugin updates
8 -- LOW	Ongoing	Automate SSL certificate renewal to prevent expiry

DISCLAIMER

This report is a portfolio sample shared publicly for demonstration purposes. All client-identifying information has been redacted including the organization name, target URL, specific domain paths, and any data that could identify the assessed business. The assessment was conducted with full written authorization from the client. All testing was non-destructive and read-only. No systems were modified and no data was accessed beyond what is publicly visible.